

Le post-quantique, en trois phrases. La cryptographie qui protège aujourd'hui le web repose sur des problèmes faciles dans un sens et infaisables dans l'autre — multiplier deux grands nombres premiers est immédiat, retrouver ces facteurs demanderait des milliers d'années. Un calculateur quantique suffisamment grand rend ce retour possible : RSA et les courbes elliptiques, c'est-à-dire l'essentiel de ce qui chiffre et signe aujourd'hui, tombent d'un coup — la taille des clés n'y change rien. La cryptographie *post-quantique* désigne les algorithmes conçus pour résister à cette machine, normalisés en 2024 (ML-KEM pour le chiffrement, ML-DSA pour la signature) ; le chiffrement symétrique, lui, AES et ChaCha20, n'est pas menacé.

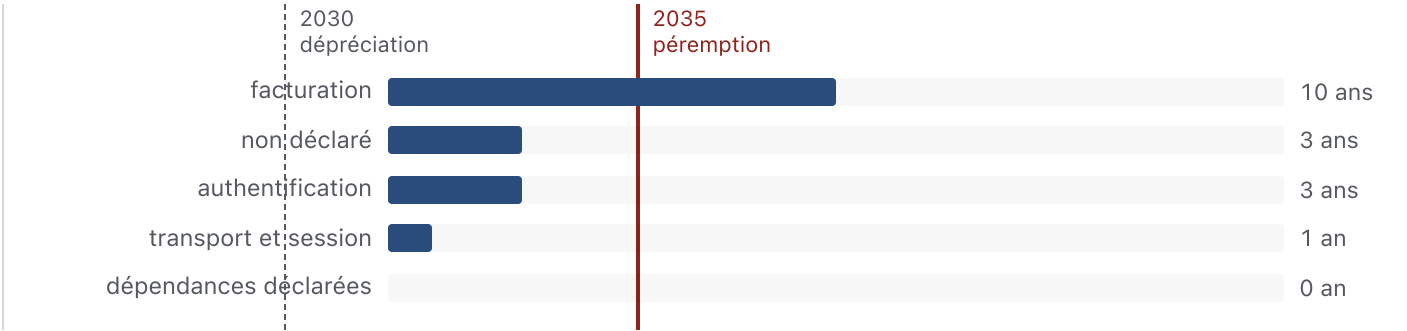
Sablir inventorie la cryptographie d'un projet et la confronte à une information qu'aucun outil ne possède : *combien de temps chaque donnée doit rester confidentielle*. Une donnée chiffrée aujourd'hui avec RSA ou une courbe elliptique, et qui doit rester secrète au-delà de la péremption de ces algorithmes, est *déjà perdue* — un adversaire capture maintenant ce qu'il déchiffrera plus tard, et la migration ne protégera que ce qui viendra après elle.

Ce rapport distingue donc ce qui se récolte (le chiffrement) de ce qui ne se récolte pas (les signatures), laisse tranquille la cryptographie symétrique, et sépare les problèmes d'aujourd'hui — MD5, SHA-1 — de l'échéance quantique.

Aucune donnée dont la durée de confidentialité dépasse la péremption des algorithmes qui la protègent.

12 constats retenus sur l'ensemble analysé. Date de péremption retenue : **2035** — c'est l'échéance réglementaire, pas une prédiction de rupture cryptographique. Échéance vérifiée auprès de ses sources le 30/09/2026.

DURÉE DE CONFIDENTIALITÉ DES DONNÉES, FACE À LA PÉREMPTION DES ALGORITHMES



Chaque barre est la durée pendant laquelle la donnée doit rester confidentielle. Elle passe en rouge quand un algorithme récoltable la protège au-delà du trait de péremption — dépasser le trait sans être rouge signifie que la donnée dure longtemps, mais qu'elle est protégée par de la cryptographie qui tiendra.

CE QUE LE SERVEUR NÉGOCIE RÉELLEMENT

showmethere`.com`

PROTOCOLE NÉGOCIÉ	SUITE	GROUPE NÉGOCIÉ
TLSv1.3	TLS_AES_256_GCM_SHA384 (256 bits)	X25519MLKEM768
SIGNATURE DU CERTIFICAT	CLÉ DU CERTIFICAT	CHAÎNE
ecdsa-with-SHA256	courbe elliptique 256 bits	3 certificats
CERTIFICAT VALIDE JUSQU'AU	VERSIONS ACCEPTÉES	
01/11/2026	TLSv1.2, TLSv1.3	

Une poignée de main, pas une lecture de fichier : c'est le seul moyen de savoir ce qui protège vraiment le trafic, et cela peut contredire ce que le dépôt déclare.

RSA dépendances déclarées **CONFIANCE MOYENNE**`composer.lock:2448``phpseclib/phpseclib`

La donnée cesse d'être sensible en 2026, avant la péremption de 2035. Migration à planifier pour le système, pas pour sauver cette donnée. Cryptographie généraliste en PHP pur. Dépendance déclarée : l'usage réel reste à confirmer.

REPLACEMENT ML-KEM (chiffrement) ou ML-DSA (signature), en hybride pendant la transition

ECDSA dépendances déclarées **CONFIANCE MOYENNE**`composer.lock:10876``web-auth/webauthn-lib`

Signature : pas de récolte possible. À migrer avant 2030 pour la conformité, sans urgence de confidentialité. Passkeys : signatures ECDSA/EdDSA côté authentificateur. Dépendance déclarée : l'usage réel reste à confirmer.

REPLACEMENT ML-DSA

SHA-1 dépendances déclarées **CONFIANCE MOYENNE**`composer.lock:4276``spomky-labs/otphp`

Dépendance déclarée employant SHA-1. Peut être imposé par la spécification du protocole, ou jamais appelé : à confirmer avant toute action. TOTP : SHA-1 par spécification, sans enjeu quantique. Dépendance déclarée : l'usage réel reste à confirmer.

REPLACEMENT SHA-256

ECDSA transport et session

tls://showmetherex.com:443

certificat signé en ecdsa-with-SHA256, clé courbe elliptique 256 bits

Signature : pas de récolte possible. À migrer avant 2030 pour la conformité, sans urgence de confidentialité.
Certificat serveur. Sa durée de vie est courte : le remplacer par une signature post-quantique se fera au renouvellement, sans migration de données.

REEMPLACEMENT ML-DSA

CONFORME **8**

SHA-256 · 7 usages Résiste aux algorithmes quantiques connus.

ML-KEM · 1 usage Normalisé FIPS 203.

PROBABLEMENT HORS SUJET **5**

SHA-256 · 4 usages Ressemble à un identifiant (clé de cache, empreinte) plutôt qu'à un contrôle de sécurité. À confirmer, pas à corriger.

MD5 · 1 usage Ressemble à un identifiant (clé de cache, empreinte) plutôt qu'à un contrôle de sécurité. À confirmer, pas à corriger.

CE QUE CE RAPPORT N'A PAS REGARDÉ

- la cryptographie de vos services gérés — base de données, stockage objet, terminaison TLS chez un intermédiaire — n'apparaît dans aucun fichier de ce dépôt
- ce qui est réellement négocié à l'exécution, pour tout hôte non déclaré dans la section « sonde »
- les clés détenues dans un HSM ou chez un fournisseur
- la durée de vie réelle des données : elle vient de votre déclaration, pas du code — un domaine non déclaré est calculé avec une durée par défaut de 3 ans

Un inventaire qui ne dit pas ce qu'il n'a pas vu n'est pas un inventaire.

CE QU'IL FAUT FAIRE, DANS L'ORDRE

Un inventaire qui ne conclut rien se range dans un dossier. Voici l'arbitrage — et l'ordre compte autant que la liste.

1 Rien d'urgent, et c'est un résultat

Aucune donnée à longue durée n'est exposée à la récolte, et rien n'est cassé aujourd'hui. Ne rien faire est ici la bonne décision : remplacer de la cryptographie qui tient coûte du temps, introduit du risque et n'améliore rien.

2 Compléter la déclaration des durées

Un domaine tourne encore avec la durée par défaut. Tant que c'est le cas, les verdicts ci-dessus sont des approximations présentées avec assurance. C'est une heure de travail avec quelqu'un qui connaît le métier et non la technique : combien de temps chaque catégorie de donnée doit-elle rester secrète ? Le fichier se relit, se discute et se versionne.

3 Remettre ce rapport au calendrier

La fenêtre se referme d'elle-même : la date de péremption ne bouge pas (2035), mais chaque année qui passe rapproche vos données de cette ligne. Un domaine conforme aujourd'hui avec une durée de neuf ans ne le sera plus l'an prochain. Rejouer l'analyse une fois par an suffit — et vérifier à cette occasion que l'échéance réglementaire n'a pas bougé.

Sablier n'envoie rien, n'enregistre rien et ne dépend de rien. Ce fichier ne charge aucune ressource externe : il peut être lu hors ligne et transmis tel quel.